Clase 13 · Atacantes y técnicas de intrusión

Seguridad Informática Básica · Dra. Cintia Quezada Reyes · martes 13 oct 2026 · Tema 3 · Apuntes y resumen de estudio

PARTE 1 · Apuntes completos

3.1 Perpetradores o atacantes

> **Definición**
> Sujetos o entidades maliciosas que **realizan o ya realizaron** una actividad maliciosa o ilícita contra la organización o sus bienes (ciberdelincuentes, agentes atacantes, delincuentes informáticos).

Agente amenazante	Atacante
Podría causar un daño; puede quedarse latente	Ejecuta la acción ilícita
"Pasa por la banqueta mirando la fachada"	"Entra a robar a la casa"

Al terminar su acción, el atacante vuelve a ser agente amenazante. **No son sinónimos** (la profesora lo marcó tras el examen).

Intencionalidad: un ataque no siempre es premeditado: quien se tropieza con un café hirviendo y quema a otra persona causó un daño sin intención.

3.2 Internos y externos

Internos (insiders)	Externos (outsiders)
Dentro de la organización o con conocimiento íntimo; saben "de qué pata cojea"	Operan fuera del perímetro físico o lógico
Muchos ataques no intencionales: ignorancia, descuido, negligencia, nepotismo	Rara vez tienen éxito solos: se apoyan en un interno (engaño, ingeniería social)
Ej.: empleado de ventanilla mal capacitado; llamadas de broma al 911	Ej.: preguntar "¿estudias en Ingeniería?" y obtener rutina y horarios

Blindar solo el perímetro no sirve si el personal regala información.

3.3 Tipos de atacantes según su acción

El atacante es el sujeto; el ataque, la acción (como corredor y carrera).

Atacante	Acción / motivación
Spammer	Spam: envío masivo de mensajes no deseados
Spoofer	Spoofing: suplantación de IP, DNS, MAC o dispositivo

Ingeniero social / phisher	Ingeniería social / phishing
Hacker	Se impone retos técnicos para demostrarse capaz, no por dinero
- Sombrero blanco	Hacking ético: encuentra vulnerabilidades para reportarlas
- Sombrero negro	Ataca con intención de dañar
- Sombrero gris	Cambia de postura según la necesidad
- Sombrero azul	Evaluadores de seguridad de corporativos (Microsoft)
Cracker	Ataca **a cambio de algo**: dinero, fama, reconocimiento
Hacktivista	Causas políticas, sociales o ideológicas
Novato / lamer / script kiddie	Corre scripts ajenos sin entenderlos; a menudo se infecta él mismo

Error común: suponer que todo hacker es malo o que todo ataque lo hace un hacker.

3.4 Red Team y Blue Team

- **Red Team:** enfoque ofensivo; imita tácticas reales para romper los controles y evaluar las defensas.
- **Blue Team:** enfoque defensivo y de recuperación; monitorea, bloquea intrusiones, ejecuta planes de respuesta.
- Una misma persona puede tener roles distintos; lo importante es mitigar y cerrar vías de entrada, no ponerle nombre al atacante.

3.5 Técnicas de intrusión y su mitigación

Se estudian para prevenirlas, corregirlas y monitorearlas, no para ejecutarlas.

Hoax (alerta falsa): "borra el archivo 138L.dll, es un virus"; el usuario lo borra y daña su propio sistema. Error: corregir sin verificar.

Técnica	Qué hace	Mitigación
Escaneo de puertos	Buscar puertos abiertos para explotarlos	Abrir solo los necesarios; filtrar en firewall
Man-in-the-Middle	Interceptar tráfico en redes abiertas (PC Puma)	IDS/IPS
Sniffing (usmeo)	Escuchar la red en modo promiscuo para capturar credenciales	Segmentar la red
DoS / DDoS	Peticiones masivas que saturan un servidor	Firewall que bloquee IP con peticiones anormales
Exploits (desbordamiento de búfer, inyección SQL)	Aprovechar fallas, sobre todo en sistemas sin actualizar	Parches periódicos y **sandboxing**
Phishing	Engaño masivo e impersonal	Capacitación práctica, MFA

Spear phishing	Dirigido, tras investigar a la víctima en redes	Capacitación, MFA
Pretexting	Inventar un escenario para sacar información ("se te cayó un billete")	Concientización

DoS real: en las Salas A y B, 50–100 alumnos entraban a la vez a la misma página; el proveedor lo tomó como DoS desde la IP pública de la Facultad y la bloqueó.

Avisos

- Tarea de investigación sobre tipos de atacantes → SIB-T03 (entregada).

PARTE 2 · Resumen para estudiar

Versión corta de lo que más probablemente se pregunta. Léela primero y vuelve a la Parte 1 si algo no queda claro.

> **Agente amenazante ≠ atacante (examen)**
>
> El agente amenazante es potencial; el atacante ejecuta la acción y al terminar vuelve a ser agente. Hay ataques sin intención.

Internos vs. externos. El interno conoce el entorno (muchas veces daña por descuido); el externo casi siempre necesita a un interno.

Hacker vs. cracker. Hacker = reto técnico (blanco, negro, gris, azul). Cracker = a cambio de algo. Hacktivista = causa. Script kiddie = scripts ajenos.

Red Team ataca para evaluar; **Blue Team** defiende y recupera.

Técnica	Defensa
Escaneo de puertos	Firewall, solo puertos necesarios
MITM	IDS/IPS
Sniffing	Segmentación
DoS/DDoS	Bloqueo de IP anómala
Exploits	Parches y sandboxing
Phishing / spear phishing / pretexting	Capacitación y MFA
Hoax	Verificar antes de "corregir"